Clinical AI QA: P2 Fix Report

Source: Clinical AI QA Test Report (8 Nov 2026) | Commits dc56962 (12 Nov) and 47e4b6d (14 Nov)

Result: 5 of the 8 P2 items are fixed and deployed. Issues 8 and 17 are partly fixed: two-factor sign-in was built and then removed on 14 Nov by decision, and password reset emails cannot be delivered from production yet because no mail server is set up. Issue 10 is not fixed: the API is still on the sslip.io address and nothing is hosted in Saudi Arabia.

P2 status against the QA list

Issue	QA request	Status	What was done
3	Privacy and Terms with Saudi content (PDPL, DPO, Saudi law) in English and Arabic	**Fixed**	Both pages rewritten in English and Arabic: PDPL rights, SDAIA as the authority, Saudi governing law, a DPO contact (dpo@esap.ai) and a plain statement that ESAP is **not yet hosted in Saudi Arabia**. Still marked "Draft, not yet reviewed by counsel".
7	Ops Incidents: breach flag, 24 h / 72 h timers, notification templates	**Fixed**	An incident can be flagged as a breach when it is opened or later. It gets two deadlines from the time ESAP became aware: 24 h to tell the affected hospital and 72 h for the hospital to notify SDAIA. Hospital and SDAIA notification templates are filled in from the incident.
8	MFA for admins, account settings, lockout, 15–30 min idle timeout	**Partly fixed**	Done: lockout for 15 minutes after 5 wrong passwords (also for unknown addresses), sign-out after 30 minutes idle, and an Account page with "Change my password". Two-factor sign-in was built and enforced for admins, then **removed on 14 Nov 2026 by decision**. No account has two-factor today.
9	Versioned processing consent and retention purge with reports	**Fixed**	Patients give or withdraw processing consent by purpose and version, and withdrawing stops AI use of their data. Stopping sharing now records the withdrawal time. A retention purge runs every 24 h and on demand from the admin console, and writes a report each time.
10	API on an ESAP domain (e.g. api.care.esap.ai) and a Saudi hosting plan	**Not fixed**	The site still calls esap-api.159-195-83-232.sslip.io. api.care.esap.ai does not answer yet. The security policy already allows it, so the switch needs DNS, a certificate and one setting. No Saudi host has been chosen.
11	"Demo · synthetic data only" badge on every page, including the app and login	**Fixed**	A badge is in the header of the public site, the sign-in and sign-up pages and every signed-in screen, including the intake form.
13	Security headers (CSP, frame, nosniff, referrer) and token in an HttpOnly cookie	**Fixed**	The site sends CSP, X-Frame-Options DENY, nosniff, Referrer-Policy and Permissions-Policy. Access-Control-Allow-Origin is care.esap.ai, not *. The session is an HttpOnly cookie and no token is kept in localStorage.
17	Self-service password reset for solo clinicians and patients	**Partly fixed**	Built: "Forgot password" sends a reset link by email and the person sets a new password on /reset-password. The answer is the same for unknown addresses. **Production has no mail server set up**, so the email is not sent there yet.

Changes since the P1 report

Issue 1 (shared demo password) is still open. On 12 Nov every account got its own password and the demo list was switched off. Later that day /demo-role came back for the clinical and patient roles. On 14 Nov the six admin and ops demo accounts were set back to the shared password as well, so 14 accounts now use it. With two-factor removed, anyone who has the shared password can sign in as Hospital Admin or Super-Admin. No real data should be put behind these accounts.

Verification

Check	Result
Backend tests (14 Nov, after two-factor removal)	357 passed, including the P2/P3 tests in test_qa_p2, test_qa_followup and test_release_check
Frontend tests	203 passed, 9 skipped
Typecheck and production build	Clean
Live site checks (14 Nov)	Security headers present on /product; API calls still go to sslip.io; api.care.esap.ai does not respond

Deployment: the backend and frontend fixes went live on 12 Nov (commit dc56962). Two-factor sign-in was removed from production on 14 Nov (commit 47e4b6d).

QA retest guide

Issue	Retest steps and expected result
3	Open /privacy and /terms, then switch the language to Arabic. Expect PDPL rights, SDAIA, Saudi governing law, dpo@esap.ai and "not yet hosted in Saudi Arabia", and in Arabic expect lang="ar" and right-to-left text.
7	Needs the Super-Admin account. Ops > Incidents > new incident with "breach" ticked. Expect 24 h and 72 h deadlines and the hospital and SDAIA templates. An incident opened without the flag can be flagged later.
8	Enter a wrong password 5 times: expect a lockout message for 15 minutes. Sign in, leave the tab for 30 minutes, then click: expect to be signed out. Profile menu > Account > Change my password works. No code is asked at sign-in (two-factor removed).
9	Patient > Settings: give and then withdraw processing consent and check the version and withdrawal time. Hospital Admin > Audit > Retention: run the purge and expect a report.
10	DevTools > Network on any app page. Today calls go to sslip.io (not fixed).
11	Open /product, /evidence, /login, /signup, the doctor worklist and New encounter. Expect the "Demo · synthetic data only" badge in the header of each.
13	Check the response headers of /product. After sign-in, DevTools > Application: the session cookie is HttpOnly and localStorage has no esap.token.
17	Needs a mail server on production. Until then, test on a server with ESAP_SMTP_* set: Forgot password > email arrives > set a new password > sign in.

Remaining before the pilot

- **API domain:** move the API to api.care.esap.ai (Issue 10). Until then Safari and some Firefox settings block the cross-site sign-in cookie, so people get signed out when they reload.
- **Saudi hosting:** choose a CST-licensed Saudi host. The Privacy page says ESAP is not hosted there yet.
- **Mail server:** set ESAP_SMTP_* on production so password reset emails are delivered (Issue 17).

- **Shared demo password:** 14 accounts, including admin and Super-Admin, use it, and two-factor is gone (Issue 1).
- **Legal review:** counsel should review the Privacy and Terms drafts, and the DPO's name should be published before real patient data is used.